

Industrial Challenges in Secure Continuous Development

Fabiola Moyón
fabiola.moyon@siemens.com
Siemens Technology and Technical
University of Munich
Germany

Florian Angermeir
angermeir@fortiss.org
fortiss
Germany

Daniel Mendez
daniel.mendez@bth.se
Blekinge Institute of Technology and
fortiss
Sweden and Germany

ABSTRACT

The intersection between security and continuous software engineering has been of great interest since the early years of the agile development movement, and it remains relevant as software development processes are more frequently guided by agility and the adoption of DevOps. Several authors have contributed studies about the framing of secure agile development and secure DevOps, motivating academic contributions to methods and practices, but also discussions around benefits and challenges. Especially the challenges captured also our interest since, for the last few years, we are conducting research on secure continuous software engineering from a more applied, practical perspective with the overarching aim to introduce solutions that can be adopted at scale. The short positioning at hands summarizes a relevant part of our endeavors in which we validated challenges with several practitioners of different roles. More than framing a set of challenges, we conclude by presenting four key research directions we identified for practitioners and researchers to delineate future work.

CCS CONCEPTS

• **Security and privacy** → **Software security engineering**; • **General and reference** → *Empirical studies*; • **Software and its engineering** → *Agile software development*.

KEYWORDS

secure agile software engineering, secure DevOps, DevSecOps, secure continuous software engineering, security compliance, security challenges

ACM Reference Format:

Fabiola Moyón, Florian Angermeir, and Daniel Mendez. 2024. Industrial Challenges in Secure Continuous Development. In *46th International Conference on Software Engineering: Software Engineering in Practice (ICSE-SEIP '24)*, April 14–20, 2024, Lisbon, Portugal. ACM, New York, NY, USA, 3 pages. <https://doi.org/10.1145/3639477.3639736>

1 INTRODUCTION AND BACKGROUND

Combining secure development practices with continuous software development (CSD) workflows poses various challenges. How to cope with them has been in the scope of both researchers and practitioners alike for many years [5]. In our perception, a certain

consensus seems to be that the integration of security practices is, at least, difficult. This is corroborated by various secondary studies [4, 7–10, 12] and more practically oriented grey literature [3, 11] reporting on the state of the art and related challenges. However, existing recommendations require too often more empirical evaluations and especially acceptance by practitioners considering their aim at solving practical engineering challenges [2, 5]. To the best of our knowledge, while CSD has been adopted in various interpretations by large enterprises (e.g. scaled agile), the question of which security-specific challenges and needs are relevant in the context of CSD requires further exploration specifically in terms of relevance according to practitioners' target (e.g. software product security, secure development process, security strategy). We consider this of particular importance to both practitioners as well as researchers developing plausible solutions to those challenges. In this paper, we report on our study results to provide a first answer to this very question. We extend existing discussions around security challenges in agile development and, in particular, DevOps, considering two perspectives: The experiences and expert opinions of individuals, and the perspective of engineering teams. We aim to analyze how groups of practitioners perceive which challenges in their specific context, as described next.

Study Design in a Nutshell.

In brief, we conducted case studies in 3 different companies operating in highly regulated environments.

Initially, we partnered with security experts to produce a draft list of relevant challenges in the field combining pertinent practitioners and academic sources. Later, in 2019 and 2020, we held five workshops with security and CSD practitioners to refine and validate the list of challenges (see Figure 1). A *exploratory workshop* with security experts, who consult security for agile teams, delivered the final challenges. Subsequently, individuals of two focus groups reviewed and prioritized the challenges: subject experts (SE) in CSD with responsibility for security, and agile team members with cross-functional roles (AT). Our study participants chose a maximum of five challenges in CSD, that are of priority considering their common objective. Such an objective is either to improve the security of a specific software product or to implement strategies for secure agile development in their organization. The study reported here is part of our long-term investigation of our industrial partners with the goal of supporting an efficient integration of security practices in CSD. As we hope to foster the exchange and discussions around industrial challenges in CSD, we concentrate on reporting our distilled challenges and implications for further research.



This work licensed under Creative Commons Attribution International 4.0 License.

ICSE-SEIP '24, April 14–20, 2024, Lisbon, Portugal
© 2024 Copyright held by the owner/author(s).
ACM ISBN 979-8-4007-0501-4/24/04.
<https://doi.org/10.1145/3639477.3639736>

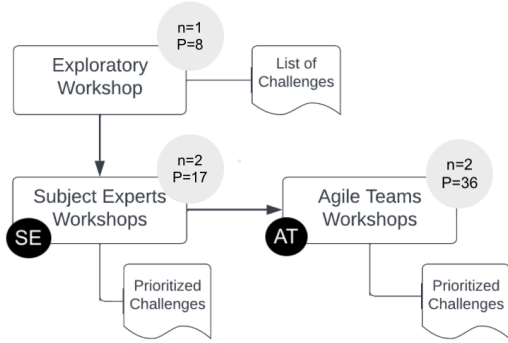


Figure 1: Summary of Study Methods. Circles in grey indicate: number of workshops n, and participants P.

2 INDUSTRIAL CHALLENGES

Our study yielded a list of prioritized challenges for security in CSD as depicted in Table 1. The challenges are grouped into five categories:

- *Continuous development*: how to perform security activities like threat modeling, secure code review, security hardening continuously, and, enabling continuous experimentation for security purposes.
- *Value Stream*: how to make security value visible to the customers through requirements, architecture or faster feedback of security vulnerabilities.
- *Efficiency*: how to achieve security for product and in the process with less impact in resources or lead time.
- *Knowledge Transfer*: how to educate teams to make effective security decisions and share knowledge.
- *CI/CD Pipelines*: how to automate security in pipelines considering its protection and compliance.

3 FUTURE RESEARCH WORK

Considering these challenges at our industrial partner, we propose the following four major takeaways as relevant for organizations adopting CSD while pertaining to regulated security environments:

- (1) *Visibility and assessment of security practices maturity for CSD based on applicable security standards* allowing practitioners to break silos between engineering and security experts teams by providing transparency of the status of security practices that regulators will expect in the development process. This includes evaluating both human and automation-based security activities e.g. secure coding review by peer-reviewed and static methods. Challenges: C1, C2, C4, C5, C7, C8.
- (2) *Implementation of continuous security feedback-loop* referring to the effective management of security-related issues, that are identified through automatic vulnerability checking by CI/CD Pipelines. Challenges: C9, C12.
- (3) *Continuous automatic security compliance* assessing capabilities and limitations of automation in continuous security compliance, e.g. by providing delta analyses with particular

Table 1: Practitioner’s Prioritized Challenges for Security in Continuous Software Development

CHALLENGE		TOTAL VOTES			
		SE W1	SE W2	AT W1	AT W2
Category 1: Security in Continuous Development					
C1	Perform threat modeling and consistently increment / adapt it throughout sprints.	7	4	4	3
C2	Include security activities into continuous deployment.	3	4	6	4
C3	Involve security aspects into continuous experimentation or prototyping.	0	1	3	4
Category 2: Security in the Value Stream					
C4	Prioritization of security requirements vs. system functionalities.	7	4	10	4
C5	Make security architecture visible in backlog and documentation.	1	8	8	0
C6	Get security activities into the early feedback principle of DevOps.	0	9	1	2
Category 3: Security Implementation Efficiency					
C7	Balance efforts for security: improving process compliance vs. improving product quality.	6	1	2	5
C8	Involve security activities with minimal burden of lead time.	1	0	7	3
Category 4: Security Knowledge					
C9	Enable security knowledge and ownership in engineering teams.	2	7	8	9
C10	Congregate experts to interchange examples about DevOps and security.	0	0	8	1
Category 5: Security into CI/CD pipelines					
C11	Effective hardening of development, test and deployment environments.	1	0	4	3
C12	Achieve efficient handling of security tool findings and involve into regular issues handling process.	0	2	6	0
C13	Selection of security tools to run in the CI/CD pipeline.	0	2	6	0
C14	Match security compliance requirements with working pipelines.	0	0	4	3
C15	Ensure protection of CI/CD pipelines.	2	2	1	0

security norms, and allowing for the development of sensible automation solutions. Challenges: C6, C7, C8, C14.

- (4) *Improvement of security skills in agile/DevOps teams* by training security champions and providing pertinent guidance on continuous security practices. This favors better decision-making about security risks in the team’s products’ continuous delivery. Challenges: C9, C10 influencing C11, C13, C15.

The relevance of the takeaways is further corroborated by our partner's decision to explicitly support them with dedicated internal research projects and doctoral studies (c.f. [1, 6, 13]).

Acknowledgements

The authors would like to thank the participants of this study, as well, as the members of the Task Forces in the industrial partners who actively support the initiative.

REFERENCES

- [1] Florian Angermeir, Markus Voggenreiter, Fabiola Moyón, and Daniel Méndez. 2021. Enterprise-Driven Open Source Software: A Case Study on Security Automation. In *43rd IEEE/ACM International Conference on Software Engineering: Software Engineering in Practice, ICSE (SEIP)*. IEEE, Los Alamitos, CA, USA, 278–287. <https://doi.org/10.1109/ICSE-SEIP52600.2021.00037>
- [2] Pranavi Bitra and Chandra Srilekha Achanta. 2021. *Development and Evaluation of an Artefact Model to Support Security Compliance for DevSecOps*. Master's thesis. Blekinge Institute of Technology (BTH), Karlskrona, Sweden. <https://urn.kb.se/resolve?urn=urn:nbn:se:bth-21106>
- [3] Gartner. 2017. 10 Things to Get Right for Successful DevSecOps. <https://www.gartner.com/en/documents/3811369/10-things-to-get-right-for-successful-devsecops>
- [4] Vaishnavi Mohan and Lotfi Ben Othmane. 2016. SecDevOps: Is It a Marketing Buzzword? - Mapping Research on Security in DevOps. In *2016 11th International Conference on Availability, Reliability and Security (ARES)*. IEEE, Los Alamitos, CA, USA, 542–547. <https://doi.org/10.1109/ARES.2016.92>
- [5] Fabiola Moyón, Pamela Almeida, Daniel Riofrío, Daniel Méndez, and Marcos Kalinowski. 2020. Security Compliance in Agile Software Development: A Systematic Mapping Study. In *46th Euromicro Conference on Software Engineering and Advanced Applications (SEAA)*. IEEE, Los Alamitos, CA, USA, 413–420. <https://doi.org/10.1109/SEAA51224.2020.00073>
- [6] Fabiola Moyón, Daniel Mendez, Tony Gorschek, Florian Angermeir, Pierre-Louis Bonvin, and Markus Voggenreiter. 2023. *A Reference Architecture for Security Compliant DevOps*. Technical Report. Blekinge Institute of Technology, Karlskrona, Sweden. <https://www.diva-portal.org/smash/record.jsf?pid=diva2%3A1771068&dsid=-8823>
- [7] Håvard Myrbakken and Ricardo Colomo-Palacios. 2017. DevSecOps: A Multivocal Literature Review. In *Software Process Improvement and Capability Determination*. Springer International Publishing, Cham, Switzerland, 17–29. https://doi.org/10.1007/978-3-319-67383-7_2
- [8] Hela Oueslati, Mohammad Masudur Rahman, and Lotfi ben Othmane. 2015. Literature Review of the Challenges of Developing Secure Software Using the Agile Approach. In *Proceedings of the 2015 10th International Conference on Availability, Reliability and Security (ARES)*. IEEE Computer Society, USA, 540–547. <https://doi.org/10.1109/ARES.2015.69>
- [9] Roshan N. Rajapakse, Mansoor Zahedi, M. Ali Babar, and Haifeng Shen. 2022. Challenges and solutions when adopting DevSecOps: A systematic review. *Information and Software Technology* 141 (2022), 106700. <https://doi.org/10.1016/j.infsof.2021.106700>
- [10] Xhesika Ramaj, Mary Sánchez-Gordón, Vasileios Gkioulos, Sabarathinam Chockalingam, and Ricardo Colomo-Palacios. 2022. Holding on to Compliance While Adopting DevSecOps: An SLR. *Electronics: Special Issue Advances in Software Engineering* 11 (2022), 3707. <https://doi.org/10.3390/electronics11223707>
- [11] Sonatype. 2019. DevSecOps Community Survey, 2019. <https://www.sonatype.com/hubfs/2019%20DevSecOps%20Community%20Survey.pdf>
- [12] Hugo Villamizar, Marcos Kalinowski, Marx Viana, and Daniel Méndez Fernández. 2018. A Systematic Mapping Study on Security in Agile Requirements Engineering. In *2018 44th Euromicro Conference on Software Engineering and Advanced Applications (SEAA)*. IEEE, Los Alamitos, CA, USA, 454–461. <https://doi.org/10.1109/SEAA.2018.00080>
- [13] Markus Voggenreiter and Ulrich Schöpp. 2022. Using a Semantic Knowledge Base to Improve the Management of Security Reports in Industrial DevOps Projects. In *Proceedings of the 44th International Conference on Software Engineering: Software Engineering in Practice, ICSE (SEIP)*. ACM, New York, NY, USA, 309–310. <https://doi.org/10.1145/3510457.3513065>